

RESEARCH

EU AI Act: Controls, Testing & Implementation

Version v2 Status Draft Project IW AI Core Platform Generated 2026-06-24

Contents

01	Executive Summary	4
02	Introduction	7
03	Background & Context	10
04	Methodology	13
05	Findings	16
06	Analysis / Discussion	24
07	Conclusion	27
08	Recommendations	30
09	Limitations	33
10	Sources	36

Field	Value
ID	R-00155
Date	2026-06-24
Mode	deep
Depth	deep
Status	draft
Author	IW AI Core (/iw-research)
Series	EU AI Act Compliance Suite (2 of 4) — see R-00154 , R-00156 , R-00157

IW Innovation Ways

CHAPTER 01

Executive Summary

CHAPTER 01

Executive Summary

For high-risk AI, the Act imposes **nine concurrent control domains** — risk management (Art. 9), data governance (Art. 10), technical documentation (Art. 11/Annex IV), logging (Art. 12), deployer transparency (Art. 13), human oversight (Art. 14), accuracy/robustness/security (Art. 15), quality management (Art. 17), and post-market monitoring + incident reporting (Arts. 72–73) — **each demanding contemporaneous documentary evidence, not after-the-fact attestation** [HIGH]. Conformity is proven via either self-assessed internal control (Annex VI) or third-party notified-body assessment (Annex VII), ending in a CE mark, EU Declaration of Conformity, and EU-database registration [HIGH]. For Article 50 transparency (live 2 Aug 2026), the Commission's 10 June 2026 Code of Practice names **C2PA Content Credentials** as the primary machine-readable marking mechanism, with invisible watermarking (e.g. SynthID) as a complementary layer [HIGH]. Crucially, **no CEN-CENELEC harmonized standard is yet in force** — only prEN 18286 (QMS) has reached public enquiry — so today companies lean on **ISO/IEC 42001 + 23894 + 42005** and must document every design choice with auditable rationale [MEDIUM].



IW Innovation Ways

CHAPTER 02

Introduction

CHAPTER 02

Introduction

This is document 2 of the four-part EU AI Act Compliance Suite. [R-00154](#) established *what applies to whom and when*; this document answers the next question a company must face: once it knows an obligation applies, *what must it actually build, and how does it prove the control works?* Compliance under the Act is not a matter of attestation — it is a matter of contemporaneous, auditable evidence. This research therefore frames the operational and testing side of the regime, so that engineering, risk, and quality teams know what to implement and how to verify it before an assessor or auditor asks.

Why this research

Objectives

The primary question this research answers: **what must a company actually *implement* to comply with the EU AI Act, *how* does it test/audit and evidence each control, and *which* standards should it certify against?** The objective is to map each high-risk control domain to concrete implementation artifacts, a corresponding test or audit method, the evidence that satisfies an assessor, and the applicable (or emerging) standard.

Scope

In scope: the nine high-risk control domains (Arts. 9, 10, 11/Annex IV, 12, 13, 14, 15, 17, 72–73), the conformity-assessment pathways (Arts. 43/47/48/49, Annexes VI/VII), Article 50 synthetic-content marking, Article 4 AI literacy, the standards stack (ISO/IEC 42001, 23894, 42005; CEN-CENELEC harmonized EN suite; NIST AI RMF), and the tooling landscape. Out of scope and treated as sibling documents in the suite: which obligations apply to whom and the regulatory timeline ([R-00154](#)), and the broader business/roadmap framing ([R-00156](#), [R-00157](#)).

IW Innovation Ways

CHAPTER 03

Background & Context

CHAPTER 03

Background & Context

This document assumes the post-Omnibus timeline established in [R-00154](#): high-risk obligations for Annex III systems move to 2 Dec 2027 and for Annex I products to 2 Aug 2028, while Article 4 literacy, Article 50 marking for new outputs, and GPAI obligations remain on their original dates. The runway is generous but deceptive — Annex III technical documentation and quality-management systems take 12–18 months to build, so the later deadline is not a start gun.

The Act's high-risk regime is best understood as **nine concurrent control domains** that must operate together across the system lifecycle: risk management (Art. 9), data governance (Art. 10), technical documentation (Art. 11/Annex IV), logging (Art. 12), deployer transparency (Art. 13), human oversight (Art. 14), accuracy/robustness/security (Art. 15), quality management (Art. 17), and post-market monitoring plus serious-incident reporting (Arts. 72–73). These are not sequential checkboxes; each is a continuous obligation with its own evidentiary trail.

The cross-cutting principle behind all of them is **contemporaneity**: the Act repeatedly requires controls to be "established, implemented, documented and maintained" as living processes, and documentation drawn up after the fact fails the standard. Evidence must be generated *as* the system is designed, trained, tested, and operated — version-controlled, timestamped, and traceable from raw data through to the deployed model. This principle, more than any single article, shapes how a compliant programme must be built.

IW Innovation Ways

CHAPTER 04

Methodology

CHAPTER 04

Methodology

This research draws primarily on authoritative and primary sources: the consolidated regulation text on **EUR-Lex** (Regulation (EU) 2024/1689); the article-level **AI Act Explorer** and the Commission's official **AI Act Service Desk**; the Commission's **Code of Practice on AI-Generated Content**; standards bodies **ISO/IEC** and **CEN-CENELEC** (JTC 21); and **NIST** for the AI RMF crosswalk. Secondary sources (law-firm analyses, governance-vendor guides, technical write-ups) are used for practitioner detail and are labelled by credibility in the Sources table.

Confidence is declared per finding on a three-point scale:

- **HIGH** — supported by primary law, official Commission sources, or a published standard; little interpretive ambiguity.
 - **MEDIUM** — supported by credible secondary analysis or by standards not yet in force; some interpretation or forward-looking judgement involved.
 - **LOW** — fast-moving or fragmented evidence (e.g. tooling landscapes) where the picture is indicative rather than settled.
-

IW Innovation Ways

CHAPTER 05

Findings

CHAPTER 05

Findings

The risk management system must be "established, implemented, documented and maintained" as a "continuous iterative process ... throughout the entire lifecycle" — not a one-time pre-launch assessment ([Art. 9](#)). It identifies foreseeable risks (including misuse), evaluates them, folds in post-market data, and adopts mitigations until residual risk is documented as acceptable. Testing must run against **metrics and probabilistic thresholds defined *before* testing** ([Service Desk Art. 9](#)). *Evidence:* a living risk register, a pre-signed metric/threshold table, dated test reports with pass/fail, and named residual-risk sign-offs.

F1 — Art. 9 risk management is a continuous lifecycle process, tested against pre-defined thresholds [HIGH]

F2 — Art. 10 data governance: quality criteria, bias testing, and a GDPR-compatible pathway [HIGH]

Training/validation/test data must be "relevant, sufficiently representative, and to the best extent possible free of errors and complete" ([Art. 10](#)). Art. 10(5) explicitly permits processing **special-category data when strictly necessary to detect and correct bias** — a GDPR-compatible route for fairness testing ([AI Governance Desk](#)). *Evidence:* dataset cards with provenance, representativeness analysis, and disaggregated fairness metrics (demographic parity, equalized odds, calibration) via Fairlearn or IBM AIF360.

F3 — Art. 11 + Annex IV technical documentation: nine sections, 10-year retention, must be contemporaneous [HIGH]

Annex IV mandates nine sections (system description, development elements, monitoring/control, performance-metric justification, risk management, change log, standards applied, the DoC, and the post-market monitoring plan) ([Annex IV](#)). Practitioners report 50–200+ page files; retention is 10 years (Art. 18). **Post-hoc documentation fails the contemporaneity standard**, and a model card covers only ~30–40% of Annex IV ([Annexa guide](#)). *Evidence:* version-controlled docs proving pre-deployment timestamps and data lineage from raw source to deployed model.

F4 — Arts. 12–15 are embedded design requirements, not bolt-ons [HIGH]

Logging (Art. 12) must be built into the architecture — biometric systems have prescribed minimum log fields. Instructions for use (Art. 13) must cover six mandated content areas. Human oversight (Art. 14) must let operators understand limits, counter automation bias, interpret/override output, and **safe-stop** the system — with **dual human verification** for biometric identification ([Art. 14](#)). Accuracy/robustness/security (Art. 15) requires declared metrics and adversarial resilience against the **five enumerated threat vectors**: data poisoning, model poisoning, adversarial examples/evasion, confidentiality attacks, and model flaws ([Art. 15](#), [Securiti](#)). *Evidence:* UI walkthrough of the five oversight capabilities, stop-button test, and red-team reports covering each Art. 15(5) vector.

F5 — Art. 17 quality management is a 13-component documented system [HIGH]

The QMS spans 13 components from regulatory-compliance strategy through a named accountability framework ([Art. 17](#)). **prEN 18286** — the first AI-Act harmonized standard to enter public enquiry (30 Oct 2025) — targets Art. 17 directly and is expected ~Q4 2026; until OJ citation, **ISO/IEC 42001** is the closest certifiable framework but covers only ~60–70% of Art. 17, so EU-specific supplements must be documented ([Lumenova](#)).

F6 — Conformity assessment has two pathways; CE mark, DoC, and registration close it out [HIGH]

Why: the single most consequential branch for a high-risk provider is which conformity route applies — it determines cost, timeline, and whether a notified body is on the critical path.

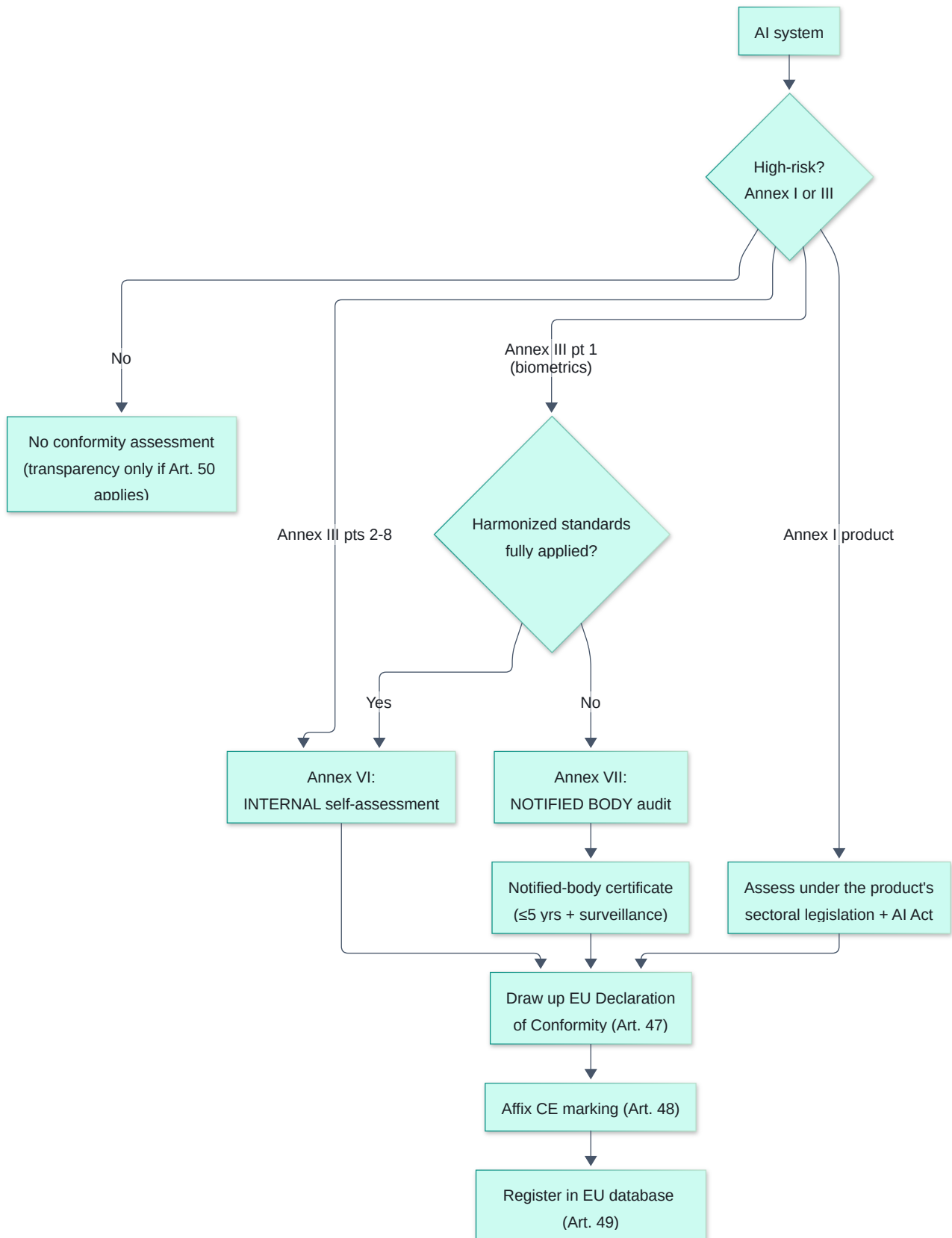


Figure 1. Conformity-assessment pathways for high-risk AI. Most Annex III systems self-assess (Annex VI); biometric systems without full harmonized-standard coverage need a notified body (Annex VII) (source: [Art. 43](#), [Annex VI](#), [Art. 49](#)).

The DoC (Art. 47, format in Annex V) is machine-readable, signed, retained 10 years; GPAI models are **not** registered under Art. 49 (separate transparency track).

F7 — Arts. 72–73: active post-market monitoring with tight incident-reporting windows [HIGH]

Post-market monitoring (Art. 72) must "actively and systematically collect, document and analyse" performance data; the plan is part of Annex IV ([Art. 72](#)). Serious-incident reporting (Art. 73) has **tiered deadlines: 2 days** (widespread infringement / critical-infrastructure disruption), **10 days** (death), **15 days** (standard) ([Taylor Wessing](#)). *Evidence*: an incident classification framework, a tested notification chain (run a tabletop drill), and pre-populated report templates.

F8 — Art. 50 marking: C2PA Content Credentials + invisible watermarking as a dual layer [HIGH]

Why: Art. 50 is the *imminent* (Aug 2026) obligation and the most concrete to implement — the pipeline below is what "machine-readable marking" actually means in practice.

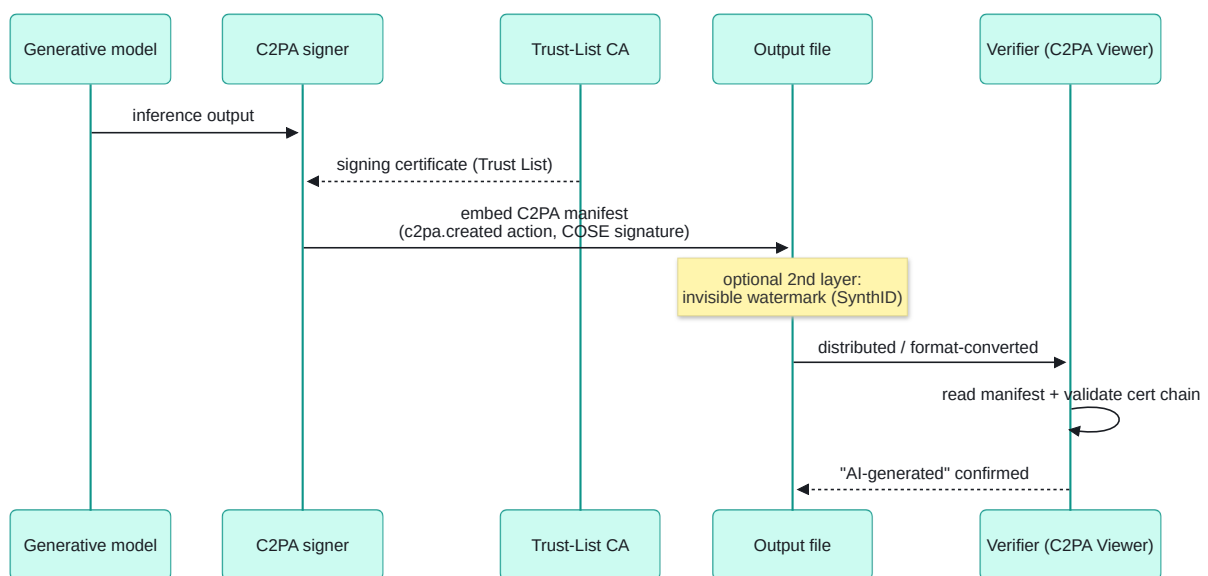


Figure 2. Article 50(2) content-marking pipeline. C2PA provides the verifiable machine-readable manifest; an invisible watermark adds robustness when content passes through non-C2PA-aware tools (source: [Code of Practice](#), [C2PA + AI Act](#)).

C2PA satisfies the four mandated criteria (effective, interoperable, robust, reliable).

Implementation: obtain a Trust-List CA certificate, integrate the C2PA SDK into the output pipeline, document it in the model card, and offer a verification endpoint. *Test detectability* by uploading samples to a C2PA viewer and confirming the manifest, signer, `c2pa.created` action, and certificate validity ([BeyondScale](#)).

F9 — Art. 4 AI literacy: a role-proportionate, documented program (enforced from Aug 2026) [MEDIUM]

No mandatory curriculum, but supervision starts 2 Aug 2026, so good-faith proportionality must be evidenced ([Art. 4](#), [Commission Q&A](#)). *Evidence*: a role-classification matrix, per-tier curricula, delivery records with timestamps, and a periodic-review cycle.

F10 — Standards stack: ISO 42001 + 23894 + 42005 today; harmonized EN suite pending [MEDIUM]

ISO/IEC 42001 (AI management system) is the only currently *certifiable* standard and maps to the Act (Art. 9 → Cl. 6.1; Art. 17 → Cl. 4–10; Art. 72 → Cl. 9.1), covering ~60–70% ([ISACA](#)). ISO/IEC 23894 supplies the risk methodology; ISO/IEC 42005:2025 the impact-assessment process ([ISO 42005](#)). The CEN-CENELEC JTC 21 harmonized suite (prEN 18228/18284/18229-1/18229-2/18282/18283/18286...) is targeted for first publication ~Q4 2026, conferring presumption of conformity only once OJ-cited ([CEN-CENELEC](#), [standards tracker](#)). Recommended layering: **EU AI Act = legal floor, NIST AI RMF = risk methodology, ISO 42001 = certifiable management shell** ([NIST crosswalk](#)).

F11 — Tooling: no single platform covers all nine domains [LOW]

A typical stack combines: experiment tracking/model registry (MLflow, W&B) for development evidence; fairness libraries (Fairlearn, AIF360) in CI/CD; drift/monitoring (Arize, Evidently) for Arts. 15/72; data lineage (Collibra, Atlan, DVC) for Art. 10/Annex IV; and a GRC layer (Credo AI, Holistic AI, OneTrust) for policy mapping and audit files ([tools comparison](#)). No vendor is end-to-end.

Control → How to Test / Evidence (condensed)

Control	Article	Implement	Test / Evidence	Standard
Risk management	9	Living risk register; misuse analysis; pre-set thresholds	Test vs pre-defined thresholds; signed residual-risk decisions	ISO 23894; prEN 18228
Data governance	10	Dataset cards; representativeness; bias exam	Disaggregated fairness metrics; drift tests	ISO 42001 Cl.8; prEN 18284
Technical docs	11/Annex IV	All 9 sections; docs-as-code; 10-yr retention	Annex IV gap analysis; contemporaneity & lineage audit	ISO 42001 Cl.7.5; prEN 18229-1
Logging	12	Automatic logging in architecture	Log-field inspection; retention check	prEN ISO/IEC 24970
Deployer transparency	13	Instructions covering 6 areas	Review vs Art. 13 list; version match	prEN 18229-1
Human oversight	14	5 capabilities; stop button; dual-verify biometrics	UI walkthrough; override + stop tests	prEN 18229-1
Accuracy/robustness/security	15	Declared metrics; adversarial defenses	Red-team the 5 Art.15(5) vectors; pen-test	prEN 18229-2/18282; ISO 27001
Quality management	17	13-component written QMS	Internal QMS audit; accountability matrix	ISO 42001; prEN 18286
Post-market monitoring	72	Monitoring plan in tech docs	Architecture review; periodic review records	ISO 42001 Cl.9; prEN 18228
Incident reporting	73	Classification + 2/10/15-day chain	Notification drill; template readiness	ISO 42001 Cl.10
Conformity + CE + register	43/47/48/49	Annex VI/VII assessment; DoC; CE; EU DB	Self-assessment evidence or NB certificate; registration record	prEN 18286
Synthetic-content marking	50(2)	C2PA manifest; Trust-List cert; watermark layer	Verify via C2PA viewer; format-conversion resilience	C2PA v2.x; CoP 2026
AI literacy	4	Role mapping; proportionate training	Role matrix; delivery records	—

IW Innovation Ways

CHAPTER 06

Analysis / Discussion

CHAPTER 06

Analysis / Discussion

The findings converge on a single cross-cutting theme: **contemporaneity is the binding constraint across every control domain**. Whether it is the Art. 9 risk register that must be a "continuous iterative process," the Annex IV documentation that fails if drawn up post-hoc, or the Art. 72 monitoring data that must be "actively and systematically" collected, the Act consistently rewards evidence generated *during* the lifecycle and penalizes retrospective reconstruction. This reframes compliance from a documentation exercise into an engineering-discipline problem: the controls must be wired into the development pipeline (version control, CI/CD fairness and adversarial tests, automatic logging, drift monitoring) so that the audit trail is a by-product of building the system rather than a separate workflow.

The second theme is the **standards gap**. ISO/IEC 42001 is the only certifiable management framework today, but it covers only ~60–70% of the Act's requirements (F5, F10), and no CEN-CENELEC harmonized EN standard is yet OJ-cited, so none confers presumption of conformity. The practical consequence is that the residual ~30–40% — the EU-specific obligations not captured by ISO — must be self-documented with explicit, auditable rationale, and every design choice made against a not-yet-final standard (prEN 18286 and the wider JTC 21 suite, expected ~Q4 2026) carries the risk of later realignment. Until then, the defensible posture is layering: the AI Act as legal floor, NIST AI RMF as risk methodology, and ISO 42001 as the certifiable shell, with the gap explicitly bridged in writing.

Conclusion

CHAPTER 07

Conclusion

A company complies by implementing all nine high-risk control domains as contemporaneously evidenced, lifecycle-long processes — not as pre-launch checkboxes — testing each against pre-defined thresholds, closing out conformity through the Annex VI self-assessment or Annex VII notified-body route into a CE mark, EU Declaration of Conformity, and EU-database registration, and certifying today against ISO/IEC 42001 (supplemented by 23894 and 42005) while the harmonized EN suite remains pending. The single most important "so what" is that documentation cannot be retrofitted: because the Act treats contemporaneous, traceable evidence as the proof of compliance, the controls have to be engineered into the build pipeline from the start, and the standards gap means the EU-specific portion ISO does not cover must be self-justified in writing. For the imminent Article 50 marking obligation (Aug 2026), the concrete answer is C2PA Content Credentials as the machine-readable layer with invisible watermarking as a complementary safeguard. The runway granted by the Omnibus timeline is real but should be spent now, because the documentation and quality-management systems that prove compliance take longer to build than the deadlines suggest.

IW Innovation Ways

CHAPTER 08

Recommendations

CHAPTER 08

Recommendations

1. **Document during development, never after** — contemporaneity is a legal requirement (Art. 11).
 2. **Adopt ISO/IEC 42001 now** as the management-system foundation; document the EU-specific 30–40% supplement explicitly.
 3. **Use the Omnibus runway, don't waste it** — Annex III docs/QMS take 12–18 months to build; 2 Dec 2027 is not a start gun.
 4. **Integrate C2PA now** for any generative output (4–8 weeks for SDK + certificate + verification); Aug 2026 is firm for new outputs.
 5. **Make bias + adversarial testing CI/CD-native**, with production drift monitoring and documented thresholds.
 6. **Pre-build the incident workflow** (classification, named chain, templates) and run a tabletop drill — the 2-day window is unforgiving.
 7. **Finish AI-literacy role mapping immediately** — fastest-to-action obligation, no Omnibus extension.
 8. **Name owners** — a Data Governance Officer and AI Risk Owner with documented accountability (Art. 17(1)(m)).
 9. **Engage a notified body early** for Annex III point-1 (biometric) systems — capacity is constrained.
-

IW Innovation Ways

CHAPTER 09

Limitations

CHAPTER 09

Limitations

- **No harmonized standard is OJ-cited yet** — none confers presumption of conformity; prEN 18286 is closest (~Q4 2026, OJ citation likely 2027). Document your own specifications meanwhile.
 - **Digital Omnibus not yet formally adopted** (as of 24 Jun 2026) — extended deadlines are politically settled but not law.
 - **Art. 72 monitoring-plan template** (due 2 Feb 2026) status unclear — don't wait for it.
 - **Notified-body ecosystem is underdeveloped** — queue delays likely for Annex VII.
 - **Non-signatory Art. 50 obligations** — SynthID-alone adequacy (without C2PA) not officially confirmed for non-signatories.
 - **Small-subgroup bias testing** — the Act prescribes no minimum sample size; methodology must be self-justified.
-

IW Innovation Ways

CHAPTER 10

Sources

CHAPTER 10

Sources

#	Title	Credibility	URL
1	Regulation (EU) 2024/1689 — EUR-Lex	High (primary law)	https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng
2	AI Act Explorer — Art. 9	High	https://artificialintelligenceact.eu/article/9/
3	AI Act Service Desk — Art. 9 (Commission)	High (official)	https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-9
4	AI Act Explorer — Art. 10	High	https://artificialintelligenceact.eu/article/10/
5	AI Governance Desk — Art. 10 data governance	Medium	https://aigovernancedesk.com/article-10-high-risk-ai-data-governance/
6	AI Act Explorer — Annex IV	High	https://artificialintelligenceact.eu/annex/4/
7	Annexa — Annex IV documentation guide	Medium	https://annexa.eu/blog/eu-ai-act-annex-iv-documentation/
8	AI Governance Desk — technical-docs checklist	Medium	https://aigovernancedesk.com/eu-ai-act-technical-documentation-checklist/
9	AI Act Explorer — Art. 14 Human Oversight	High	https://artificialintelligenceact.eu/article/14/
10	AI Act Explorer — Art. 15	High	https://artificialintelligenceact.eu/article/15/
11	Securiti — Art. 15 analysis	Medium	https://securiti.ai/eu-ai-act/article-15/
12	AI Act Explorer — Art. 17 QMS	High	https://artificialintelligenceact.eu/article/17/
13	Lumenova — prEN 18286 analysis	Medium	https://www.lumenova.ai/blog/pren-18286-eu-ai-act-standard/
14	AI Act Explorer — Art. 43 Conformity Assessment	High	https://artificialintelligenceact.eu/article/43/
15	AI Act Explorer — Annex VI Internal Control	High	https://artificialintelligenceact.eu/annex/6/
16	AI Act Service Desk — Art. 47 DoC	High (official)	https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-47
17	AI Act Explorer — Art. 49 Registration	High	https://artificialintelligenceact.eu/article/49/
18	AI Act Service Desk — Art. 48 CE Marking	High (official)	https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-48
19	AI Act Explorer — Art. 72 Post-Market Monitoring	High	https://artificialintelligenceact.eu/article/72/
20	AI Act Explorer — Art. 73 Incident Reporting	High	https://artificialintelligenceact.eu/article/73/
21	Taylor Wessing — serious-incident deep dive	Medium-High (law firm)	https://www.taylorwessing.com/en/insights-and-events/insights/2025/10/eu-ai-act-deep-dive
22	AI Act Explorer — Art. 50 Transparency	High	https://artificialintelligenceact.eu/article/50/
23	Commission — Code of Practice on AI-Generated Content	High (official)	https://digital-strategy.ec.europa.eu/en/policies/code-practice-ai-generated-content
24	C2PA Viewer — C2PA & EU AI Act	Medium (technical)	https://c2paviewer.com/articles/eu-ai-act-content-credentials

25	BeyondScale — Art. 50 watermarking guide	Medium	https://beyondscale.tech/blog/eu-ai-act-article-50-watermarking-compliance
26	AI Act Explorer — Art. 4 AI Literacy	High	https://artificialintelligenceact.eu/article/4/
27	Commission — AI Literacy Q&A	High (official)	https://digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers
28	ISACA — ISO 42001 & EU AI Act pairing	Medium-High	https://www.isaca.org/resources/news-and-trends/industry-news/2025/isoiec-42001-and-eu-ai-act-a-practical-pairing-for-ai-governance
29	ISO — ISO/IEC 42005:2025	High (primary standard)	https://www.iso.org/standard/42005
30	CEN-CENELEC — AI standardization news	High (standards body)	https://www.cencenelec.eu/news-events/news/2025/brief-news/2025-10-23-ai-standardization/
31	NIST — AI RMF ↔ ISO 42001 crosswalk	High (official)	https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf
32	AI Act Standards — harmonized standards tracker	Medium	https://ai-act-standards.com/
33	Conformity assessment — arXiv technical paper	Medium (technical)	https://arxiv.org/html/2512.13907v3
34	AI Governance Desk — tools comparison 2026	Medium	https://aigovernancedesk.com/best-ai-governance-tools/
35	Credo AI — EU AI Act toolkit	Medium (vendor)	https://www.credo.ai/eu-ai-act
36	Commission — AI Act standardisation policy	High (official)	https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation